

Structured Training Program: Wi-Fi

Module 6: Security in Wi-Fi

1. What are the pillars of Wi-Fi security?

Pillars of Wi-Fi Security

1. Authentication — Verifying the identity of a device/user before granting network access
2. Encryption — Protecting data in transit so it cannot be read if intercepted
3. Integrity — Ensuring data is not tampered with during transmission (via MIC — Message Integrity Code)
4. Access Control — Controlling who can connect (e.g., 802.1X, PSK, MAC filtering)
5. Key Management — Secure generation, distribution, and rotation of encryption keys

2. Explain the difference between authentication and encryption in Wi-Fi security.

Aspect	Authentication	Encryption
Purpose	Proves who you are	Protects what you send
When it happens	Before network access is granted	After authentication, during data transfer
Examples	PSK, 802.1X/EAP, SAE	TKIP, CCMP (AES), GCMP
Analogy	Showing your ID at the door	Speaking in a secret language inside

Authentication without encryption = identity verified but data exposed. Encryption without authentication = data protected but anyone can connect. Both are required for true security.

3. Explain the difference between WEP, WPA, WPA2 and WPA3?

Feature	WEP	WPA	WPA2	WPA3
Year	1997	2003	2004	2018
Encryption	RC4 (40/104-bit)	TKIP (RC4)	CCMP (AES-128)	GCMP (AES-192/256)
Integrity	CRC-32 (weak)	MIC (Michael)	CBC-MAC	GMAC
Key Exchange	Static, manual	Pre-shared	Pre-shared / 802.1X	SAE (Dragonfly)
Security Level	Broken/Insecure	Weak (interim fix)	Strong	Very Strong
Forward Secrecy	No	No	No	Yes

PMF Support	No	No	Optional	Mandatory
--------------------	----	----	----------	-----------

4. Why is WEP considered insecure compared to WPA2 and WPA3?

- Weak IV (Initialization Vector): Only 24-bit, reused frequently — attackers can collect enough packets to crack the key statistically
- RC4 vulnerabilities: RC4 stream cipher has known cryptographic weaknesses
- Static keys: Same key is used for all devices — no per-session or per-device keys
- Weak integrity (CRC-32): CRC is not cryptographically secure; attackers can modify packets without detection
- No mutual authentication: Only the client authenticates to the network, not vice versa
- Crackable in minutes: Tools like Aircrack-ng can break WEP in under 5 minutes by capturing ~50,000 IV packets

WPA2 uses AES-CCMP with dynamic per-session keys and a proper MIC, making it exponentially harder to crack.

5. Why was WPA2 introduced?

WPA was an emergency interim standard using TKIP (still based on RC4) because WEP was broken. WPA2 was introduced to:

- Replace the weak RC4/TKIP with AES-CCMP (Counter Mode with CBC-MAC Protocol)
- Provide FIPS 140-2 compliant encryption for government and enterprise use
- Introduce proper per-session, per-client encryption keys via the 4-way handshake
- Support 802.1X enterprise authentication more robustly
- Enforce Message Integrity Checks (MIC) using cryptographically secure methods

WPA2 became mandatory for all Wi-Fi certified devices from 2006 onward.

6. What is the role of pairwise master key (PMK) in 4-way handshake?

The PMK is the root secret from which all session keys are derived.

- In Personal mode (PSK): PMK = PBKDF2(passphrase, SSID, 4096 iterations) — both client and AP derive this independently
- In Enterprise mode (802.1X): PMK is delivered by the RADIUS server after EAP authentication

During the 4-way handshake, the PMK is never transmitted. Instead, both sides use it to derive the PTK (Pairwise Transient Key) using:

$$\text{PTK} = \text{PRF}(\text{PMK} + \text{ANonce} + \text{SNonce} + \text{AP MAC} + \text{Client MAC})$$

The PTK is then split into:

- KCK — Key Confirmation Key (for MIC verification)
- KEK — Key Encryption Key (encrypts GTK delivery)
- TK — Temporal Key (encrypts actual data traffic)

7. How does the 4-way handshake ensure mutual authentication between the client and the access point?

The 4-way handshake proves both sides know the PMK without ever sending it:

AP ————— Message 1: A-Nonce —————> Client

(AP sends its random nonce)

AP <———— Message 2: S-Nonce + MIC ————— Client

(Client computes PTK, sends S-Nonce + MIC proving it knows PMK)

AP ————— Message 3: GTK + MIC —————> Client

(AP verifies client's MIC, sends Group Key — proves AP knows PMK)

AP <———— Message 4: ACK ————— Client

(Client confirms receipt — both sides install keys)

- Client is authenticated because it can produce a valid MIC using the derived PTK
- AP is authenticated because it can also produce a valid MIC in Message 3
- Neither side transmits the PMK or PTK — only proofs derived from them

8. What Happens if a Wrong Passphrase is Entered During the 4-Way Handshake?

1. Client derives an incorrect PMK from the wrong passphrase
2. Client generates SNonce and computes an incorrect PTK
3. Client sends Message 2 with an MIC calculated using the wrong PTK
4. AP calculates the expected MIC using the correct PTK — they don't match
5. AP silently discards Message 2 — no error message is sent for security reasons
6. AP may retry (resend Message 1) a few times, then times out the handshake
7. Client receives a disconnection/association failure and cannot join the network

This is also what makes offline dictionary attacks possible — an attacker captures Message 2, then tries millions of passphrases offline to find one whose MIC matches.

9. What problem does 802.1X solve in network?

In PSK-based networks, everyone shares the same password. If one device is compromised, the entire network is at risk, and revoking access requires changing the password for all users.

802.1X solves this by providing:

- Individual identity-based authentication — each user has unique credentials
- Centralized access control via a RADIUS server
- Per-user, per-session encryption keys — one user's traffic cannot be decrypted by another
- Granular revocation — disable one user without affecting others
- Audit trails — RADIUS logs who connected, when, and for how long
- Support for certificates, OTP, smart cards via EAP methods

10. How 802.1X Enhances Security over Wireless Networks?

802.1X implements a three-party architecture:

Client (Supplicant) <—EAP—> Access Point (Authenticator) <—RADIUS—> Auth Server

Security enhancements:

- Port-based access control: The AP blocks all traffic except EAP until authentication succeeds — the client is logically isolated
- Dynamic key generation: PMK is delivered by RADIUS per session — no shared static key
- EAP method flexibility: Supports EAP-TLS (certificates), PEAP (username/password), EAP-TTLS, etc.
- Mutual authentication: With EAP-TLS, both the server and client present certificates — prevents rogue AP attacks
- Session isolation: Each client gets unique encryption keys — no user can sniff another's traffic even on the same AP
- Seamless revocation: Disabling a user in Active Directory/RADIUS immediately blocks their access
- PMF (Protected Management Frames): WPA2/WPA3 Enterprise mandates protection against deauthentication attacks